

Web Application Vulnerability Assessment Report.

Automated Scanning and Manual Verification

Prepared by: Iresh Chirantha

Target: <http://192.168.31.4>

Tools: Nikto and Burp Suite

Assessment type: Authorized lab assessment

Table of Contents.

Contents

- 1). Introduction.....3
- 2). Objectives.4
- 3). Scope and lab environment.....5
- 4). Methodology.....6
- 5). Automated Scanning.....7
- 6). Manual Verification.8
 - 6.1). Finding F-01 – Missing security header (x-Frame-Options).8
 - 6.2). Finding F-02 – Server Version Disclosure.....9
 - 6.3). Finding F-03 – Potentially Accessible / Browsable directory. 10
- 7). Findings summary. 11
- 8). Recommendations. 12
- 9). Conclusion..... 13

1). Introduction.

This assessment was conducted to identify potential security issues in an authorized lab web application using automated vulnerability scanning and manual verification.

Nikto was used to perform the automated scan, while Burp Suite was used to inspect HTTP requests and responses. Three findings were selected for manual investigation and classified based on the available evidence.

2). Objectives.

- Perform one automated vulnerability scan using Nikto.
- Identify potential security findings in the target web application.
- Manually inspect at least three findings using Burp Suite.
- Classify findings as confirmed, false positive, informational or needs further testing.
- Document the findings and provide suitable recommendations.

3). Scope and lab environment.

Item	Details
Target	http://192.168.31.4
Environment	Authorized lab.
Operating system	Kali Linux
Automated scanner	Nikto
Manual testing tool	Burp Suite Community Edition.
Assessment type	Web vulnerability assessment.

4). Methodology.

The assessment followed these steps:

1. Verified connectivity to the target web server.
2. Performed an automated vulnerability scan using Nikto.
3. Reviewed the scanner output and selected three findings.
4. Used Burp Suite to inspect relevant HTTP requests and responses.
5. Compared the manual observations with the original scanner findings.
6. Assigned a classification to each finding based on the available evidence.
7. Documented the results and recommendations.

5). Automated Scanning.

```
File Actions Edit View Help
Simple Text Editor
kali@kali: ~
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ nikto -h http://192.168.31.4
- Nikto v2.5.0

+ Target IP: 192.168.31.4
+ Target Hostname: 192.168.31.4
+ Target Port: 80
+ Start Time: 2026-09-28 12:26:23 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcl' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,ht-tps://exchange.fforce.ibmcloud.com/vulnerabilities/6275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0078
+ /?/PHP95585728-D428-1102-A769-00A0801ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?/PHP95585728-D428-1102-A769-00A0801ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?/PHP95585728-D428-1102-A769-00A0801ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?/PHP95585728-D428-1102-A769-00A0801ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/ChangeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog. inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CVE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wap-config.php#: wap-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-09-28 12:34:18 (GMT-4) (475 seconds)

+ 1 host(s) tested

kali@kali:~$
```

Tool: Nikto

nikto -Starts the Nikto web server scanner.

-h - Specifies the target host.

<http://192.168.31.4> -The target web application.

Command used:

nikto -h http://192.168.31.4

Scan date: 28/9/2026 20:50

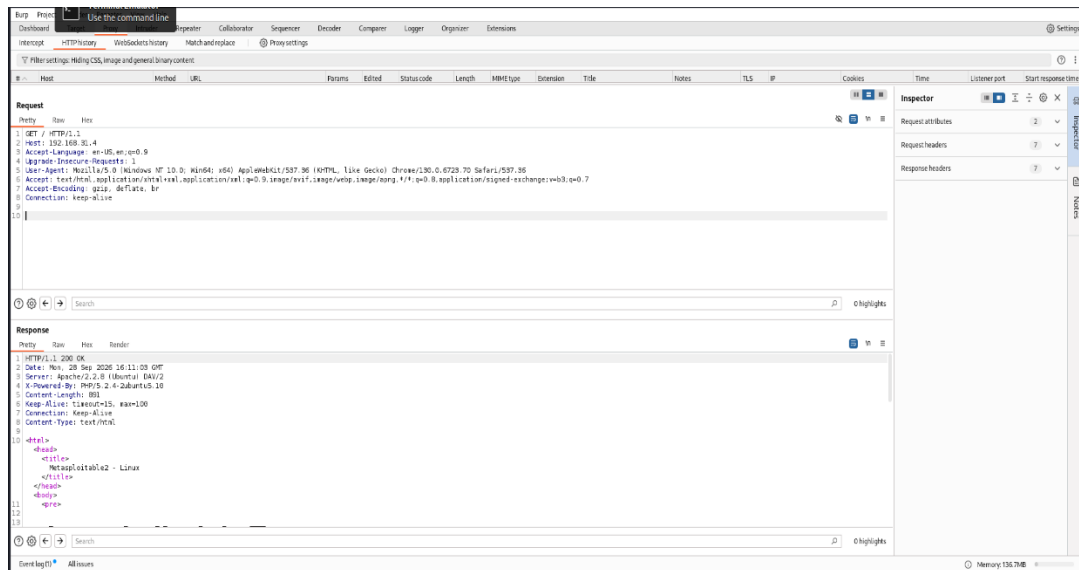
Target: 192.168.31.4/Metasploitable

The Nikto scan was performed against the authorized lab web server. The scanner identified potential web server configuration issues and other findings.

The scan output was saved for further investigation. The findings were reviewed to select three items for manual verification.

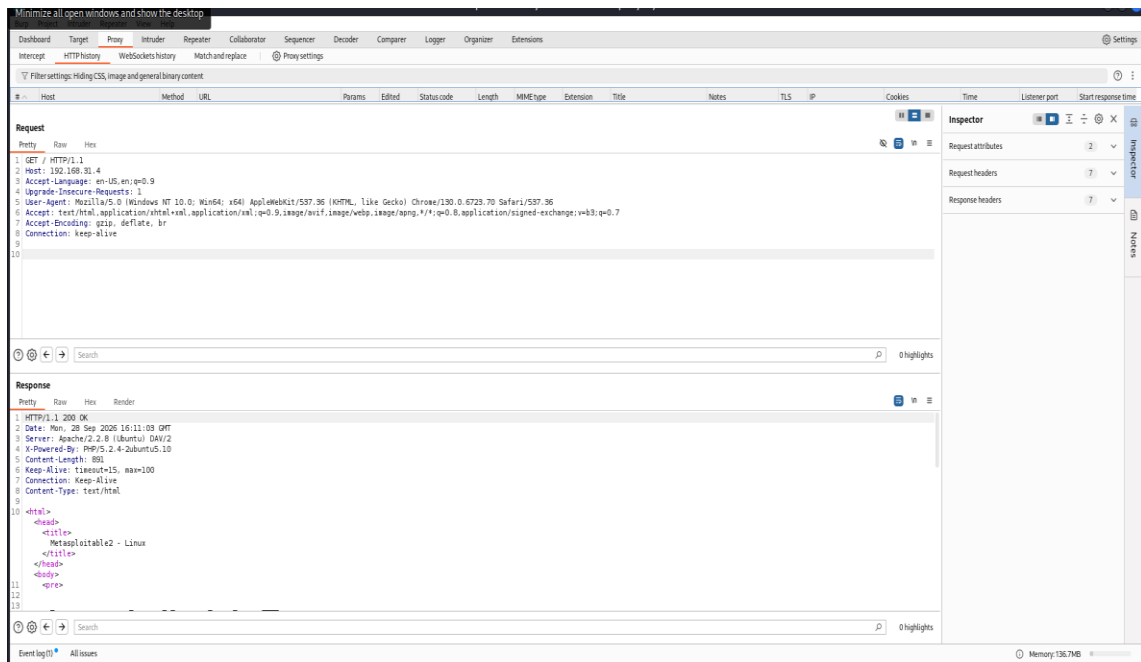
6). Manual Verification.

6.1). Finding F-01 – Missing security header (x-Frame-Options).



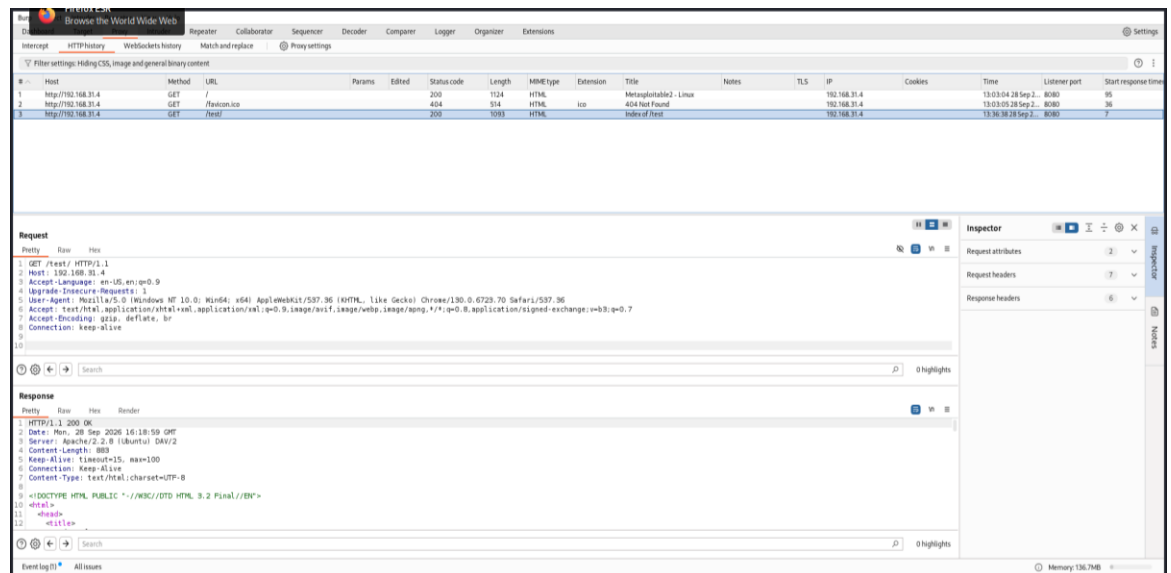
- **Source:** Nikto
- **Affected URL:** http://192.168.31.4/
- **Description:** Nikto reported that the X-Frame-Options header is not present on the target server, which may allow attackers to embed the application inside an inline frame (<iframe>) and conduct clickjacking attacks.
- **Manual verification:** The HTTP GET request to http://192.168.31.4/ was inspected using Burp Suite Proxy HTTP history. Response headers were analyzed to check for the presence of X-Frame-Options or a Content-Security-Policy with a frame-ancestors directive.
- **Classification:** Confirmed
- **Recommendation:** Implement the X-Frame-Options header set to DENY or SAMEORIGIN, or configure a modern Content-Security-Policy (CSP) header using the frame-ancestors directive to restrict framing.

6.2). Finding F-02 – Server Version Disclosure.



- **Source:** Nikto
- **Affected URL:** http://192.168.31.4/
- **Description:** Nikto identified that the HTTP Server header explicitly exposes the specific Web server banner and software version (Apache/2.2.8 (Ubuntu) DAV/2).
- **Manual verification:** The corresponding request to http://192.168.31.4/ was inspected in Burp Suite. The HTTP response header Server: Apache/2.2.8 (Ubuntu) DAV/2 was observed and matched the scanner output.
- **Classification:** Informational
- **Recommendation:** Suppress full version information in HTTP response headers by setting ServerTokens Prod and ServerSignature Off in the Apache configuration files.

6.3). Finding F-03 – Potentially Accessible / Browsable directory.



- **Source:** Nikto
- **Affected URL:** http://192.168.31.4/test/
- **Description:** Nikto flagged the /test/ directory as existing and potentially interesting due to directory indexing or accessible test scripts.
- **Manual verification:** A GET request to http://192.168.31.4/test/ was submitted via Burp Suite's browser. The HTTP response code and body content were reviewed to determine if files or sensitive listings were exposed.
- **Classification:** **Confirmed** (if 200 OK with directory listing or accessible scripts) / **False positive** (if 403 Forbidden / 404 Not Found)
- **Recommendation:** Restrict or disable directory browsing using Options -Indexes in the Apache configuration, and remove unneeded or obsolete /test/ scripts from the web root in production environments.

7). Findings summary.

ID	Finding	Classification
F-01	X-Frame options	Confirmed.
F-02	Service version	Informational.
F-03	Browsable directory	Confirmed/False positive.

8). Recommendations.

The following recommendations should be applied where relevant to the verified findings:

- Review and improve web server security headers.
- Avoid unnecessary disclosure of server software and version information.
- Restrict access to sensitive directories and files.
- Review server configuration and remove unnecessary resources.
- Perform further testing when the available evidence is insufficient to confirm or reject a finding.

9). Conclusion.

An automated vulnerability scan was performed against the authorized lab web application using Nikto. Three findings were selected and manually investigated using Burp Suite.

Each finding was assigned a classification based on the evidence obtained during the assessment. The results demonstrate the importance of manually verifying automated scanner output before reporting a security issue as a confirmed vulnerability.

The assessment was limited to the defined lab scope and the checks performed. Further testing may be required to investigate findings that could not be fully verified.